



TORIN CYBER GROUP

TABLETOP EXERCISE

PREPARING FOR AN AI DATA SPILL INCIDENT

PRESENTED BY

Shanna Daly

CEO | Torin Cyber Group



TORIN
CYBER GROUP

Version: 1.4 | August 2026

In what year was the term “Artificial Intelligence” first coined?

1945

1955

1965

1975



Artificial Intelligence (AI) is an umbrella term for technologies that perform tasks which traditionally required human intelligence.

GENERATE



- Create text
- Images
- Code
- Video

ANALYSE



- Documents
- Data
- Trends
- Risks

UNDERSTAND



- Language
- Speech
- Questions
- Context

AUTOMATE



- Workflows
- Decisions
- Repetitive tasks



GET THE WORKBOOK



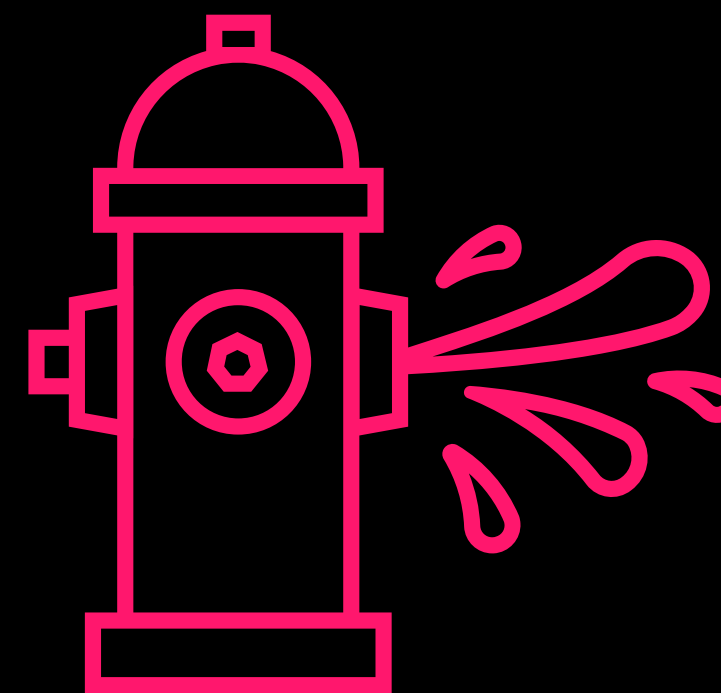


WHAT IS AN AI DATA SPILL?



An AI data spill occurs when sensitive, confidential or regulated information is entered into an AI system in a way that is unauthorised, unintended or outside an organisation's approved controls.

- A confidential document uploaded to a public AI service.
- Customer or employee information pasted into an AI prompt.
- An AI assistant connected to sensitive corporate data without approval.
- Information shared with an AI platform that has not been assessed or approved by the organisation.



This creates risk to privacy, security, compliance and reputation.

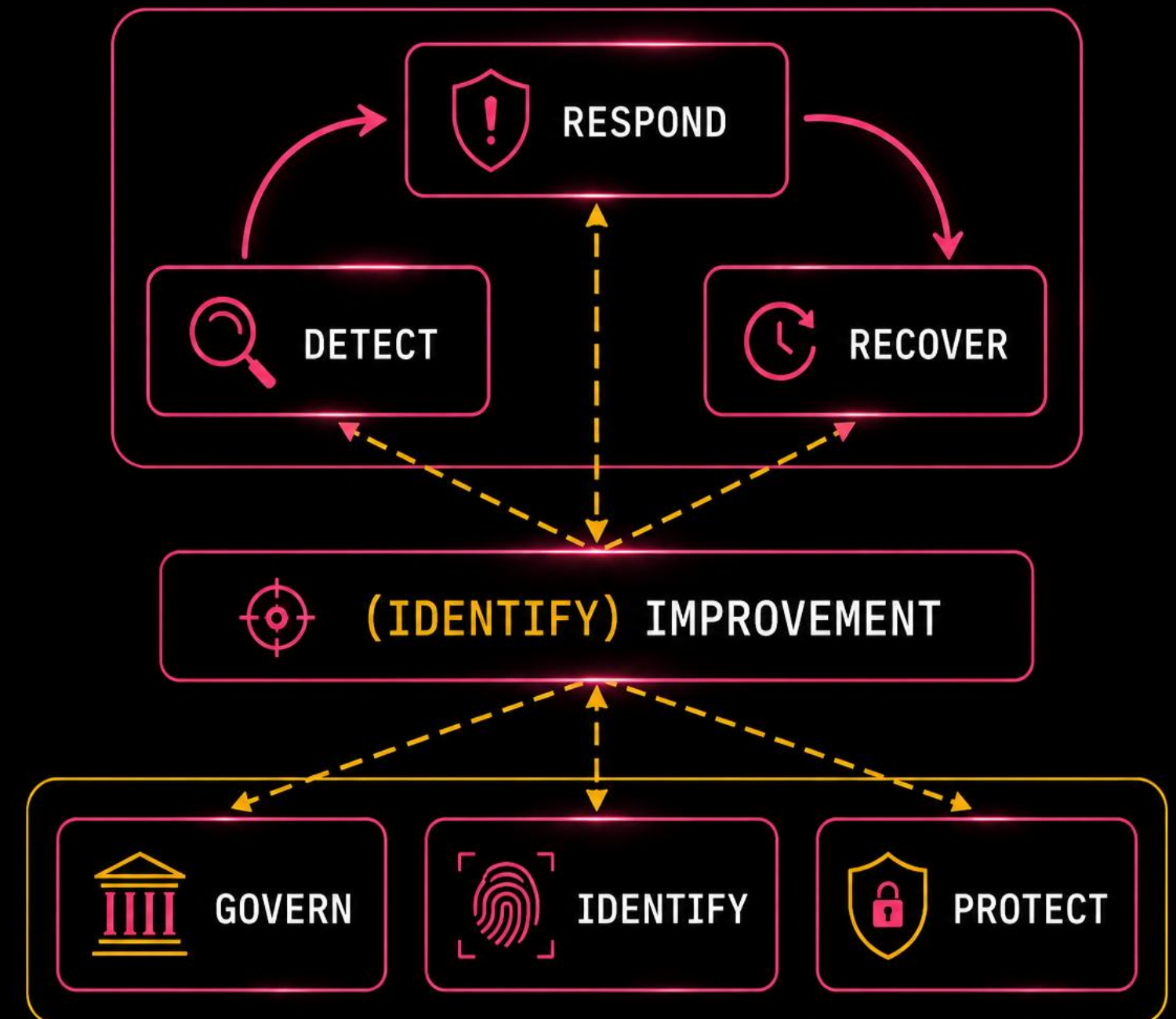
THE INCIDENT RESPONSE LIFECYCLE



TORIN CYBER GROUP

The NIST Incident Response Lifecycle provides a structured approach to managing cyber security incidents.

It helps organisations respond consistently, reduce impacts and continuously improve their security posture.





SAFETY DRILLS



AIRLINE CREWS

- Rehearse evacuations, fires, decompression, medical emergencies and other in-flight incidents (at least once a year and for pilots twice a year!).



FIREFIGHTERS

- Practice structural fires, rescues, hazardous-material incidents and multi-agency coordination.



HOSPITAL EMERGENCY TEAMS

- Run simulations for cardiac arrests, trauma cases, mass-casualty events and system outages.



OFFSHORE OIL AND GAS CREWS

- Rehearse fire response, gas leaks, abandon-platform procedures and emergency evacuation.



These professions practise emergencies repeatedly—not because incidents happen every day, but because they need to respond effectively when one does. **Cyber incident response should be treated the same way.**





TABLE-TOP EXERCISES

A tabletop exercise is a facilitated discussion that allows participants to work through a realistic scenario, make decisions, and explore how they would respond in a safe, collaborative environment.

- During today's exercise you will:
- Work through a realistic AI data spill scenario.
- Discuss decisions as new information is introduced.
- Share ideas and perspectives with others.
- Consider the technical, business and governance impacts.
- Learn practical approaches you can apply in your own organisation.



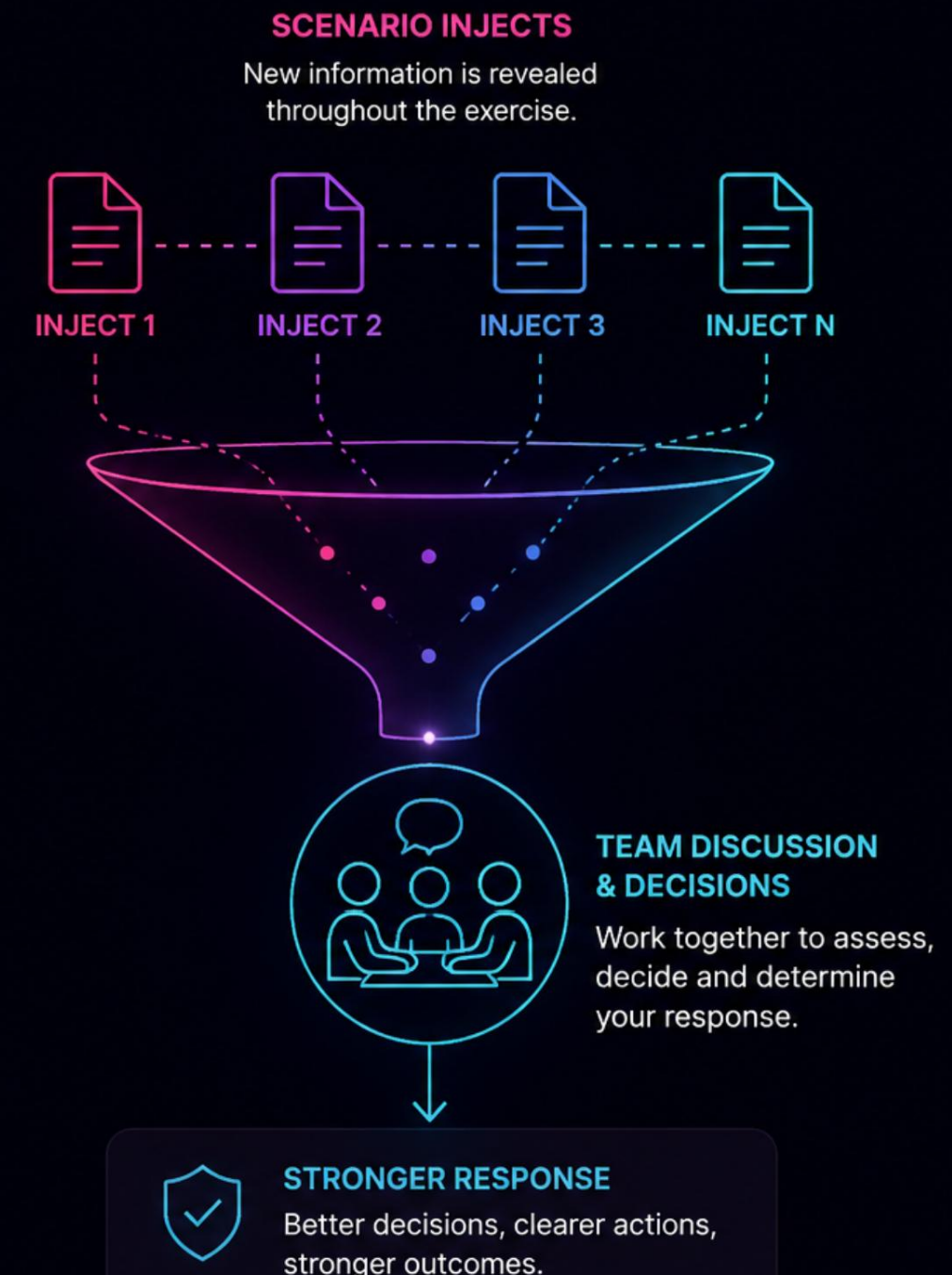
SCENARIO OVERVIEW

You will be guided through a realistic AI data spill scenario that unfolds through a series of incident updates (injects).

As new information becomes available, you'll work together to assess the situation, make decisions and discuss how you would respond.

AT EACH STAGE CONSIDER:

-  What has happened?
-  What are the immediate risks?
-  What information do we need?
-  Who needs to be involved?
-  What actions should we take next?





ROLES TO PLAY



SECURITY / IT

Contain, investigate and protect systems and data.

- Identify and contain threats
- Investigate and analyse
- Protect systems and data
- Restore secure operations



PRIVACY

Assess the privacy impact, determine regulatory obligations and advise on personal information handling.

- Assess privacy impact
- Identify regulatory obligations
- Advise on data handling
- Support notifications



LEGAL

Provide legal advice, assess contractual obligations and support regulatory decision-making.

- Provide legal guidance
- Review contracts and obligations
- Assess liability and risk
- Support regulatory matters



COMMUNICATIONS

Coordinate internal and external messaging and stakeholder engagement.

- Manage internal communications
- Prepare external messaging
- Coordinate stakeholders
- Maintain consistent updates



LEADERSHIP

Make strategic decisions, allocate resources, manage organisational risk and approve business actions.

- Set strategic direction
- Allocate resources
- Manage organisational risk
- Approve key decisions



THROUGHOUT TODAY'S EXERCISE, THINK BEYOND YOUR OWN ROLE.

Consider who else should be involved and what perspectives they bring to the response.



Different perspectives lead to

better decisions and stronger outcomes.



GROUND RULES

TO GET THE MOST VALUE FROM OUR EXERCISE, LET'S AGREE TO:



BE NICE

Respect others, listen actively and welcome different perspectives.



PARTICIPATE

Join the discussion, share your ideas and help keep the conversation moving.



NO WRONG ANSWERS

This is a learning exercise. Different viewpoints are welcome and uncertainty is part of the process.



STAY CURIOUS

Ask questions, explore options and challenge assumptions in a constructive way.



THINK OUT LOUD

Explain your thinking so others can learn, build on ideas and make better decisions together.



WE'RE A TEAM

Support each other. Our goal is to learn, improve and enjoy the exercise together.



THIS IS A LEARNING EXERCISE, NOT A TEST.
No blame. No perfect answers. Just discussion, learning and improvement.





INJECT #1

Monday, 8:15 am. Emma calls the IT Service Desk.



Emma has been with the organisation six years. Well regarded, strong performer, never involved in a security incident.



Over the weekend she was finalising a board paper for Monday's executive meeting, working to a deadline.



On Sunday evening she uploaded a large spreadsheet to a free public AI assistant to summarise it.



Afterwards she realised she had put organisational information into a tool that isn't approved for work.



She waited until the Service Desk opened on Monday morning to report it.

DISCUSSION QUESTIONS

- 01 Is this a security incident? What makes you say so?
- 02 What are the first three things you would do?
- 03 Would anyone know who to call on a Sunday evening?



INJECT #2

Monday, 10:30 am. The Service Desk escalates the matter.



Emma still has the spreadsheet and can show the team exactly what she uploaded.



Current financial performance and revenue forecasts.



Pipeline opportunities, contract values and the status of live bids.



Recently won contracts that have not yet been publicly announced.



Internal pricing assumptions and commercial strategy.



Names, job titles and contact details of key customer contacts.



She uploaded the entire file, not an extract.



Nobody knows yet what the AI provider does with files uploaded to it.

DISCUSSION QUESTIONS

- 01** How has your assessment of the incident changed?
- 02** Does anything here count as personal information? Does that change who's involved?
- 03** Agree a severity rating: low, medium, high or critical. Write it down.



INJECT #3

Monday, 1:00 pm. The team establishes how the tool was accessed.



Emma signed in with her personal email address, not her corporate account.



Work laptop, home internet connection, Sunday evening.



The service isn't on any approved list. The acceptable use policy doesn't mention AI at all.



No administrative access to the account, and no relationship of any kind with the provider.



Emma can show the team the conversation, but there's no independent record and no way to confirm nothing has been deleted or altered.



Nothing suggests this was deliberate. Emma reported it herself as soon as she realised.



Emma offers to delete the conversation straight away.

DISCUSSION QUESTIONS

- 01** Emma offers to delete the conversation. Do you let her? Who makes that call?
- 02** What should be written down or copied while it still can be?
- 03** How does using a personal account change what you can actually do?



INJECT #4

Tuesday, 9:00 am. Legal and Commercial have reviewed the file.



Several customers named in the file are covered by confidentiality clauses requiring the organisation to tell them if their confidential information is disclosed to an unauthorised third party.



One of those customers is due to announce a major contract award later this week.



Whether uploading a file to an AI service counts as a disclosure to a third party has not been tested.



The answer may depend on what the provider does with the file, which the organisation still doesn't know.



Leadership asks for an urgent assessment of who needs to be told.

DISCUSSION QUESTIONS

- 01** Is uploading to an AI service a disclosure to a third party? Who decides that where you work?
- 02** Who might you owe an explanation to? Customers, insurers, partners, the board, regulators?
- 03** Who can authorise a notification, including out of hours?



INJECT #5

Tuesday, 3:45 pm. The announcement has been brought forward.



The customer's contract award announcement has been brought forward to tomorrow morning.



It's the customer's announcement, not ours. We can't delay it. We can only ask them to hold it, and asking means explaining why.



The file names this customer, the expected contract value, the internal pricing assumptions behind the bid and the commentary on the negotiation.



The customer has been told nothing so far.



Whether the provider retained the file, or whether anyone else has seen it. We won't know before the announcement.

DISCUSSION QUESTIONS

- 01 Decide now: tell them today, ask them to hold, or say nothing yet. Three minutes.
- 02 Write the first two sentences you'd say to them on the phone.
- 03 What are the risks of waiting?



INJECT #6

Wednesday, 11:00 am. What does the provider actually do with it?



Personal account, so no support agreement, no account manager and no legal relationship. All the team has is the public Terms of Service.



Uploaded prompts and files may be retained.



Deleting a conversation may not immediately remove it from backup systems.



Whether content is used to improve the service depends on account type and settings. Free and personal accounts are commonly treated differently from business and enterprise ones.



The organisation can't confirm how Emma's account was configured at the time.



The conversation has been deleted from Emma's account. Nobody authorised it.

DISCUSSION QUESTIONS

- 01 It's been deleted and nobody authorised it. Should that have happened?
- 02 Would an approved enterprise platform have changed your response? How exactly?
- 03 Without Emma telling you, would you have detected this at all?



INJECT #7

The following week. The post-incident review.



Whatever your table decided at Inject 5, the scenario now proceeds as follows.



The customer was told before the announcement, in line with the contractual obligation.



No evidence of any further access, though there was never any means of detecting it.



Still no way to confirm whether the content was used to improve the AI service.



Leadership considers the immediate operational response complete.



Two further uploads to public AI tools come to light during the review. Neither was reported at the time.

DISCUSSION QUESTIONS

01

Can this be closed? What would closed mean here?

02

Two others did the same thing and said nothing. What does that tell you?

03

Should there be consequences for Emma?



WHAT WILL YOU DO NOW?

Turn today's scenario into stronger defences for your organisation.



STRENGTHEN GOVERNANCE

Review and update AI policies, standards and acceptable use guidelines.



PROTECT OUR DATA

Classify data, apply DLP controls and limit what can be shared externally.



BUILD AWARENESS & CAPABILITY

Educate and empower employees to use AI tools safely and responsibly.



IMPROVE DETECTION & RESPONSE

Enhance monitoring, playbooks and escalation to respond quickly and effectively.



DRIVE CONTINUOUS IMPROVEMENT

Learn from this incident, test our readiness and continuously improve our defences.



Follow us on LinkedIn

THANK
YOU!